Phishing Basics

Phishing 101

A social engineering attack to trick people into revealing sensitive information or running malware on a device. Phishing exploits human psychology rather than technical vulnerabilities.

Types of Phishing

Phishing

Attackers send the same believable message to many people at once, often using common themes like account alerts or invoices. These messages feel routine rather than personal; any details are generic or slightly off. The aim is quick wins at scale: stolen passwords, card details, or a foothold on a device.

Spear Phishing

Spear phishing is a targeted attack tailored to a specific person. The goal is usually to get the target to click a link, open a file, run a task, or submit credentials so the attacker can move deeper into the organisation's network.

Whaling

Whaling is spear phishing that targets senior decision-makers and executives, like CEOs and CFOs. Both spear phishing and whaling are targeted and customised attacks

Psychology of Phishing



Scarcity

Scarcity makes something feel rare, which pushes people to act before they think.

We can use terms like “limited seats,” “last chance,” or “ends today.”

Example: “Only three TryPhones up for grabs.”

Urgency

Urgency adds a countdown so the brain prioritises speed over scrutiny. Time pressure narrows attention and reduces deliberate checking.

Language often includes “within 24 hours,” “immediately,” or “deadline passed.”

Example: “Your account will be suspended in 12 hours unless you verify your identity through this portal.”

Authority

Authority leans on perceived status or expertise to gain quick compliance. Visual cues (titles, signatures, formal tone) and role labels (HR, IT, Finance) increase the effect.

Example: “From: IT Administrator. Action required on your SSO settings.”

Fear

Fear uses threat and alarm to trigger a protective reaction, pushing people to “fix” the problem immediately.

Wording often includes “security alert,” “breach,” or “unauthorised access.”

Example: “We detected suspicious logins on your account. Secure it immediately here.”

Curiosity

Curiosity hooks attention by promising interesting information.

Subject lines are short, intriguing, and slightly vague.

Example: “Confidential: Q3 roadmap highlights.”

Trust

Trust piggybacks on familiar brands, colleagues, or communication styles so the message feels safe by default.

Recognisable names, logos, or routines (monthly reports, ticket numbers) lower scepticism and make requests seem routine.

Example: “Microsoft 365: New security notice available in your portal,” or a message that looks like it’s from a known teammate asking for a quick review.

Phishing Techniques

URL and Domain Manipulation

As a pentester, one of our primary goals is to get our targets to click on a URL we control. To achieve this, we can use some of the techniques below:

- **URL Masking:** Involves disguising a malicious URL behind a legitimate-looking hyperlink. For example, an attacker might display `https://tryhackme.com` while redirecting users to `http://phisher.thm`.
- **Homograph Attacks:** Exploit visual similarities between domain name characters, for example, replacing **"o"** with **"0"** or using Cyrillic characters. An attacker might register a domain like `go0gle.com` that looks identical to the legitimate one but redirects users to a malicious site.

- **Typosquatting:** Involves registering domains similar to legitimate ones, relying on users making typing errors, for example, `tryhacme.com` instead of `tryhackme.com.` As a pentester, you can use these domains for phishing websites or malware delivery.

Email Spoofing Fundamentals

Email spoofing is a technique for impersonating a legitimate sender by modifying email headers.

Using some of these techniques, we can craft an email that would look like this on the recipients end:

```
From: Support <support@tryaccounting.thm>
To: bob@tryaccounting.thm
Subject: Urgent: Account Verification Required

Dear Bob,

As part of our security policy, we require all TryAccounting employees to change their passwords every
http://tryaccounting-security.thm/account

Thank you,
TryAccounting Support Team
```

At first glance, this looks like a perfectly legitimate email. Most email clients don't show these details by default, but if we were to look at the email headers, we would see the sender's true email:

```
From: Support <support@tryaccounting.thm>
Reply-To: attacker@phisher.thm
Return-Path: attacker@phisher.thm
X-Sender: attacker@phisher.thm
Received: from phisher.thm (mail.phisher.thm [192.168.1.25]) by mail.tryaccounting.thm
```

Credential Harvesting

In a login cloning attack, the attacker replicates all visual elements of the legitimate website, including logos, fonts, and form fields, and hosts them on a deceptive domain. The primary distinction lies in the destination of submitted credentials. On the authentic site, credentials are transmitted to the organisation's authentication server.

Payload Delivery Mechanisms

A frequently used delivery method involves a Microsoft Word document containing a macro. Upon opening the file, the victim encounters a prompt to "Enable Content" in order to view the

document, which serves as a built-in social engineering tactic.

The typical sequence of events is as follows:

1. The victim receives and opens the .docm attachment.
2. Microsoft Word prompts the user to enable macros.
3. The victim clicks "Enable Content."
4. The VBA macro executes a hidden command.
5. The attacker receives confirmation of execution.

Tools of the Trade

Pentesters use specific tools to create and manage realistic phishing campaigns. Below are three of the most popular tools:

GoPhish(opens in new tab) is a web-based framework that makes setting up phishing campaigns more straightforward. It allows you to store your SMTP server settings for sending emails and has a web-based tool for creating email templates using a simple WYSIWYG (What You See Is What You Get) editor. You can also schedule emails and have an analytics dashboard that shows open and click rates. You can get some hands-on experience with GoPhish in our Phishing room.

EvilNginx(opens in new tab) is a tool designed for advanced phishing campaigns that bypass multi-factor authentication (MFA). It acts as a reverse proxy between victims and legitimate sites, capturing credentials and session tokens in real time.

The Social Engineering Toolkit (SET)(opens in new tab) contains many tools. Still, some of the important ones for phishing are the ability to create spear-phishing attacks and deploy fake versions of common websites to trick victims into entering their credentials. In task 6, we will get hands-on experience with this tool.

Anatomy of a Phishing Campaign



Planning & Scoping

Start by agreeing on the mission with the client and writing it down in one sentence. Define which user groups are in or out, the techniques in bounds, and the specific outcomes to measure, for example, separating “clicked a link” from “attempted to submit credentials.” Set the campaign timing and message volume, secure legal sign-off, and record the rules of

engagement, an explicit kill switch, and emergency contacts so the exercise remains authorised, safe, and reversible.

Reconnaissance

Use only public information to make lures feel plausible without crossing privacy lines. Company websites, press releases, LinkedIn profiles, public social posts, and relevant news provide enough context to craft believable pretexts, such as referencing a recent announcement or policy change. Keep all collections within scope and document sources so it’s clear the research stayed ethical and limited to OSINT.

Scenario & Payload Development

Turn the intel into realistic but harmless messages: an invoice reminder, an IT notification, or an HR update that looks and reads like the real thing. Payloads should support learning, not exploitation: tracking links, branded landing pages that capture metadata, and benign attachments are appropriate. Avoid malware and live credential capture entirely; use simulated login pages and fake accounts to measure risk-free behaviour.

Exploitation and Post-Exploitation

Run the campaign according to the agreed plan, either in staggered waves or as a single send, and monitor opens, clicks, simulated submissions, and reports in real time. Keep the kill switch and escalation path visible to the team and pause immediately if messages leak outside the scope or trigger unintended consequences. Use lab-safe tooling, such as **GoPhish** or an equivalent sandboxed platform, and only target real users after obtaining prior written authorisation.

Reporting and Debriefing

Analyse what happened and why: click rates, submission attempts, reporting behaviour, and timing across teams. Present findings without naming individuals and focus on practical improvements like targeted training, phishing-resistant MFA, SPF/DKIM/DMARC configuration, and other technical controls that reduce risk, close with agreed follow-up actions and a sensible cadence for re-testing so progress can be measured over time. The table below provides an overview of the most common metrics used during phishing campaigns, along with some benchmarks and client recommendations.

Recommendations table

Metric	What it measures	Benchmark	Suggested Recommendation(s)
Open Rate	% of users who opened the email.	Industry varies; typical phishing open rates ~50–65%	Targeted refresher training
Click Rate	% of all users who clicked a link.	8–14% acceptable; >14% high risk	Focused security awareness training
Credential Entry Rate	% of all users who entered credentials after clicking.	<2% low risk; 2–5% moderate risk; >5% high risk	Phishing site identification training, MFA implementation
Attachment Detonation Rate	% of users who opened/executed an attachment.	No formal benchmark; >5–7% suggests risk	Educate on safe handling of attachments, Sandbox detonation
Reporting Rate (24h)	% of users who reported the email within 24h.	>40% strong; 30–40% average; <30% low	Reporting awareness campaign

The Social Engineering Toolkit

Scenario

After our OSINT investigation, we have finally identified a good target for our spear-phishing attack: Bob, the head of finance at TryAccounting. Through LinkedIn, we found this email address: bob@tryaccounting.thm. In one of their job offers for a cyber security engineer, we learnt that they:

Have a strict password policy (can be used as a good pretext in our phishing email)

Use email security, so we might need to perform some basic email spoofing

Our goal is to obtain Bob's credentials, so we will create a phishing web app to harvest them.

```
root@ip-10-128-127-131:~# ssh attacker@10.128.172.255
The authenticity of host '10.128.172.255 (10.128.172.255)' can't be established.
ED25519 key fingerprint is SHA256:gBuK8VM61oUX1/ydCHaPp6bWEzGOPEIOxPvNKcyspsE.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.128.172.255' (ED25519) to the list of known hosts.
attacker@10.128.172.255's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-1026-aws x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Wed Sep  2 18:21:42 UTC 2026

  System load:  0.08              Temperature:           -273.1 C
  Usage of /:   9.2% of 67.78GB   Processes:             127
  Memory usage: 77%               Users logged in:       0
  Swap usage:   0%                IPv4 address for ens5: 10.128.172.255

 * Ubuntu Pro delivers the most comprehensive open source security and
   compliance features.

   https://ubuntu.com/aws/pro

Expanded Security Maintenance for Applications is not enabled.

55 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status
```

Next, we need to run the Social Engineering Toolkit. There is an alias on the VM to make things easier: Just type SET and hit enter.



I selected 1

It then gave me more options

```
Select from the menu:

  1) Spear-Phishing Attack Vectors
  2) Website Attack Vectors
  3) Infectious Media Generator
  4) Create a Payload and Listener
  5) Mass Mailer Attack
  6) Arduino-Based Attack Vector
  7) Wireless Access Point Attack Vector
  8) QRCode Generator Attack Vector
  9) Powershell Attack Vectors
 10) Third Party Modules

 99) Return back to the main menu.
```

selecting 2, 3, 3

```
 HTA files which can be used for Windows-based PowerShell exploitat

   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) HTA Attack Method

  99) Return to Main Menu

set:webattack>3
```

```
The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

  1) Web Templates
  2) Site Cloner
  3) Custom Import

 99) Return to Webattack Menu

et:webattack>3
```

```
The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.128.172.255]:
```

Then, provide the following path for index.html /home/attacker/setoolkit/ and choose the first option, Copy just the index.html. And finally, enter the following URL: http://tryacounting.thm, and press enter:

```
et:webattack>3
-] Credential harvester will allow you to utilize the clone capabilities within SET
-] to harvest credentials or parameters from a website as well as place them into a rep

-------------------------------------------------------------------------------
-- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

he way that this works is by cloning a site and looking for form fields to
ewrite. If the POST fields are not usual methods for posting forms this
ould fail. If it does, you can always save the HTML, rewrite the forms to
e standard forms and use the "IMPORT" feature. Additionally, really
mportant:

f you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
P address below, not your NAT address. Additionally, if you don't know
asic networking concepts, and you have a private IP address, you will
eed to do port forwarding to your NAT IP address from your external IP
ddress. A browser doesn't know how to communicate with a private IP
ddress, so if you don't specify an external IP address if you are using
his from an external perspective, it will not work. This isn't a SET issue
his is how networking works.

et:webattack> IP address for the POST back in Harvester/Tabnabbing [10.128.172.255]:
!] Example: /home/website/ (make sure you end with /)
!] Also note that there MUST be an index.html in the folder you point to.
et:webattack> Path to the website to be cloned: /home/attacker/setoolkit/
*] Index.html found. Do you want to copy the entire folder or just index.html?

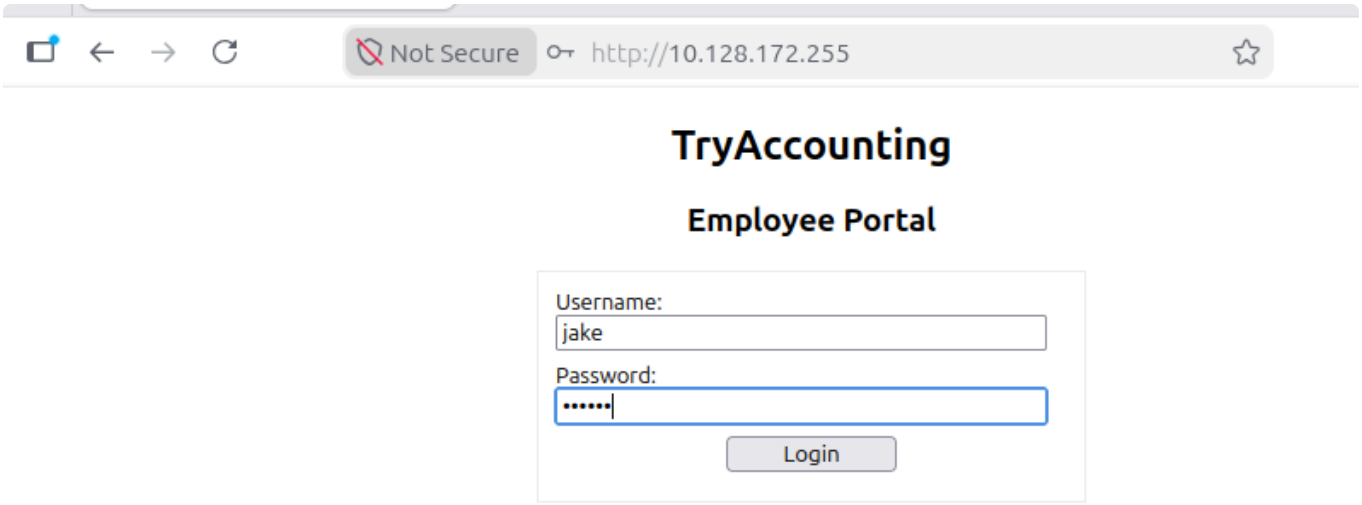
. Copy just the index.html
. Copy the entire folder

nter choice [1/2]: 1
-] Example: http://www.blah.com
et:webattack> URL of the website you imported: http://tryacounting.thm
```

```
set:webattack> URL of the website you imported: http://tryacounting.thm

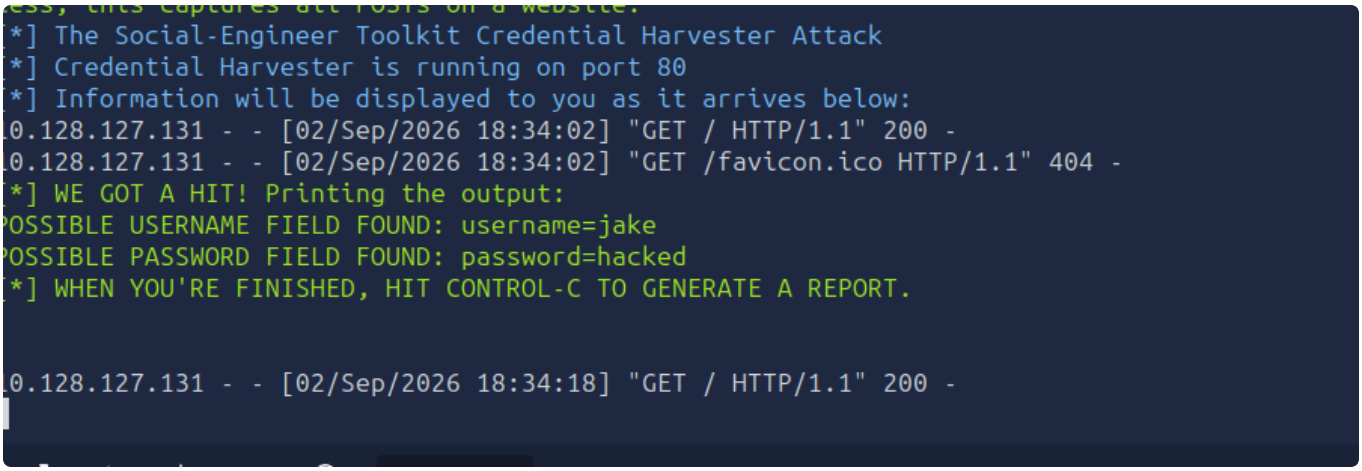
The best way to use this attack is if username and password form fields are available. Regar
less, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

this is the target website



I then entered some credentials and the site just gave an error

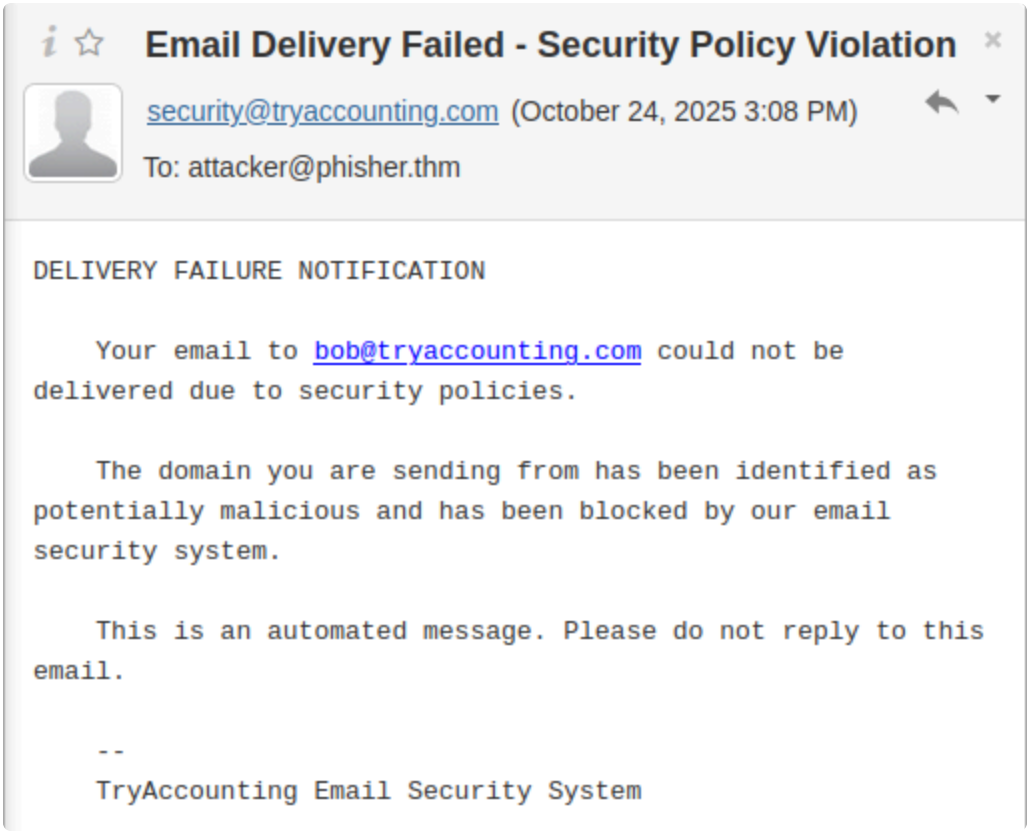
but on the credential harvester that I set up it shows the credentials I entered



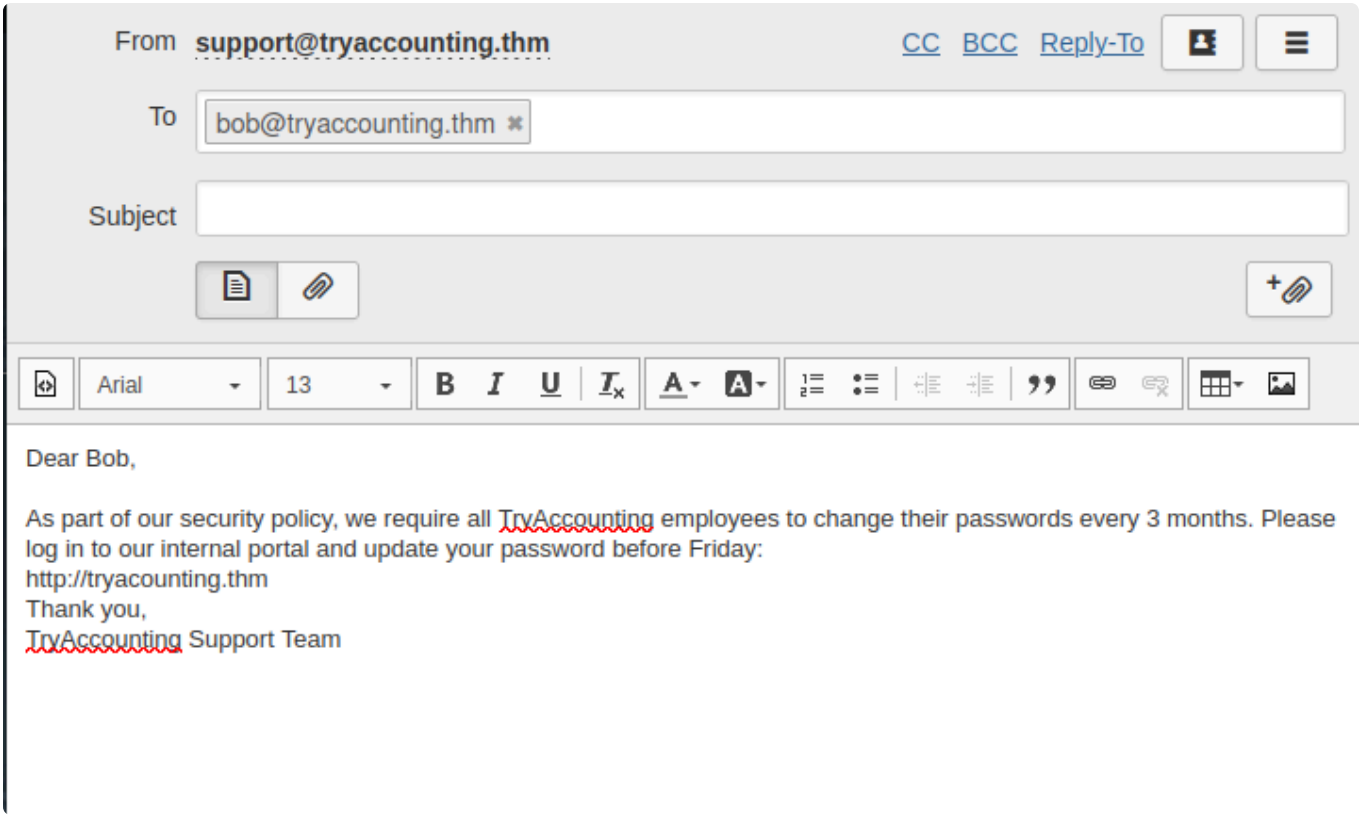
Time to Get Phishy

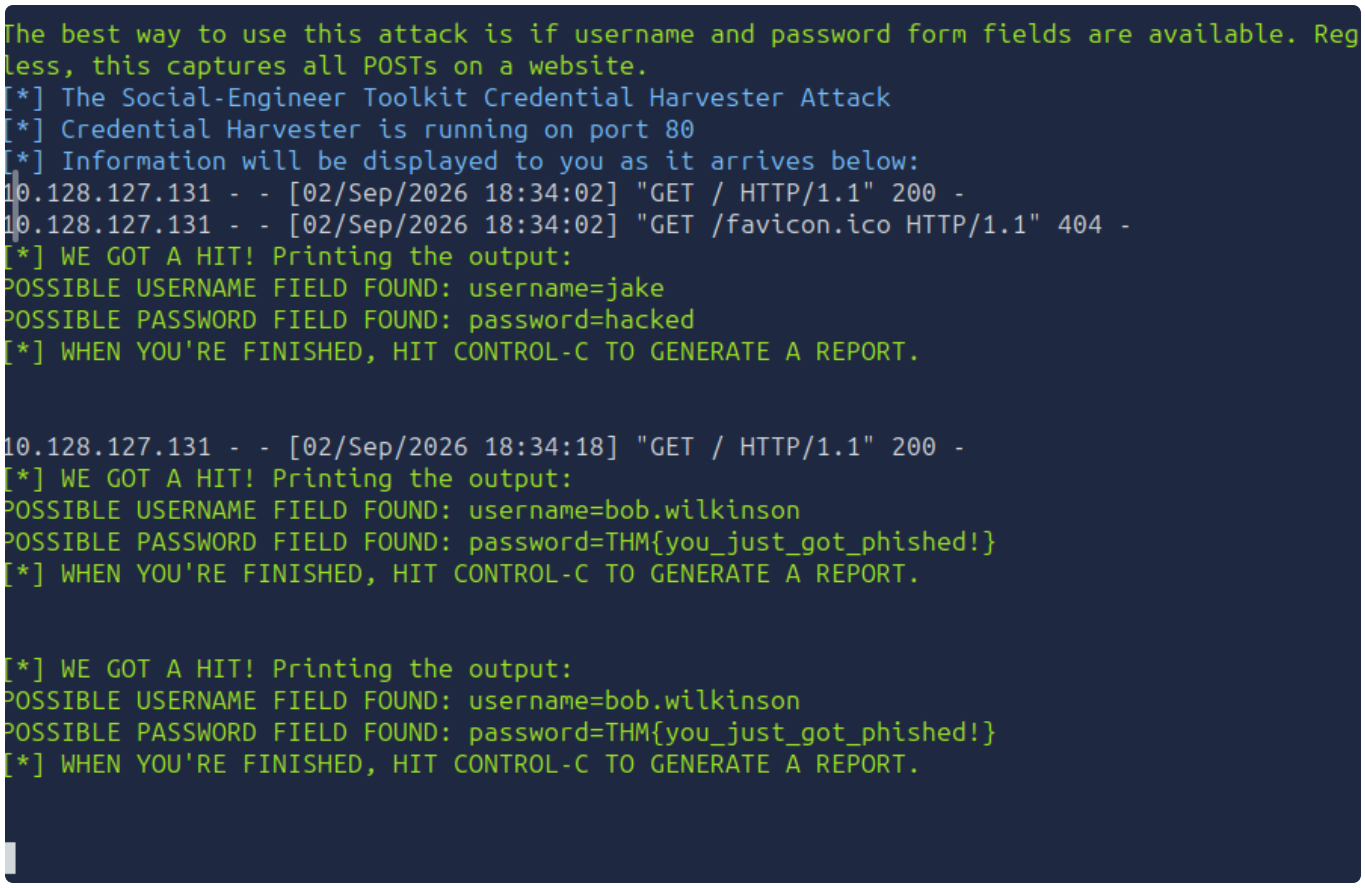
I logged into phishy to make a phishing email

During our reconnaissance phase, we discovered that TryAccounting may use email security. If we try to send an email to our target, bob@tryaccounting.thm, we will get the following response:



I selected new email then the from section there was a drop down in which i selected a support account and am going to email a user at this company. Then in the message body constructed a message that will lead to the credential harvesting site





Bob entered the details and I got the flag